06 — EU AI Act Compliance Review

Station: AI Security Officer (Regulatory Compliance & Security)
Mission: 02 | **Squadron:** Colby | **Officer:** Mubina Rahaman Jerin
Scope: `04_fst_noisy_simulator.py`, `05_Noisy_Interrogation_Transcript.md`, `logs/run_log.json` |
Legal basis: Regulation (EU) 2024/1689 (AI Act), as amended by the Digital Omnibus, Regulation (EU) 2026/1744 | **Review date:** 2026-10-16

---

1. Summary

Question	Answer
Is the simulator a prohibited practice (Art. 5)?	**No**
Is it a high-risk AI system (Art. 6, Annex III)?	**No**, as long as the FST does not control real transport or critical infrastructure
Is the FST itself an "AI system" (Art. 3(1))?	**No.** It executes rules written entirely by us (Recital 12). The LLM parts (AURA's replies, the decoder, the Anti-Turing probe) are.
Do transparency duties apply (Art. 50)?	**Yes, if deployed to users.** Two gaps found (§4)
Are we a GPAI model provider (Art. 53)?	**No.** We call Gemini/OpenAI/Anthropic models as a downstream user
Is the AI Act binding on this coursework?	**Largely not.** Research and development before market placement is excluded (Art. 2(6), 2(8)). We still apply the rules as if AURA were deployed.

Verdict: compliant in its current form as a course prototype. Before any deployment, the two Art. 50 fixes in §4 and the safety fixes in §5 are required.

2. Timeline that matters for this project

Date	What applies
2 Feb 2025	Prohibited practices (Art. 5) and AI literacy (Art. 4)
2 Aug 2025	Obligations for general-purpose AI model providers
27 Jul 2026	Digital Omnibus (Regulation (EU) 2026/1744) enters into force
2 Aug 2026	**Transparency obligations (Art. 50): in force now**
2 Dec 2026	End of the grace period for marking generative output (Art. 50(2)) of systems already on the market before 2 Aug 2026
2 Dec 2027	High-risk systems in Annex III (moved back by the Digital Omnibus)

Date	What applies
2 Aug 2028	High-risk AI inside Annex I products

3. Risk classification

Two components, two answers. Mission 2 combines a deterministic **finite-state transducer** with **LLM calls**. The FST only follows rules and patterns written by the squadron; it does not infer how to act from data. Under Art. 3(1) and Recital 12 it is therefore not an AI system. The LLM components (AURA's replies in the 10-turn interrogation, the decoder and the Anti-Turing probe) are.

Prohibited practices (Art. 5): not triggered. No subliminal or manipulative techniques, no exploitation of vulnerabilities, no social scoring, no biometrics. The Anti-Turing probe questions a model, not a person.

High-risk (Annex III): not triggered. AURA's FST books a fictional starship course. **If a real FST-plus-LLM system like this controlled vehicle navigation or another safety function of critical infrastructure (Annex III, point 2), or were a safety component of a regulated product (Annex I), it would be high-risk** and would need risk management, logging, human oversight, accuracy and robustness measures (Art. 9–15). The stress tests in `03` show why: the parser locked a wrong course after sarcasm and negation (ST2, ST5).

Education (Annex III, point 3): not triggered. The Anti-Turing probe and its 0/1/2 rubric evaluate an **LLM**, not students. If a similar rubric were used to grade students, it would fall under point 3.

Limited risk (Art. 50): applies on deployment. AURA's LLM replies talk directly to humans and generate text.

GPAI (Art. 53–55). The duties of model providers fall on Google, OpenAI and Anthropic. Our duty is to respect their usage policies and pass transparency on to our own users.

4. Article 50 checklist

#	Requirement	Status	Evidence / fix
1	Users must be told they are talking to an AI, unless obvious (Art. 50(1))	⚠ **Gap**	The transcript header names provider and model, but `--interactive` mode and AURA's replies carry no plain-language notice. **Fix:** print "*You are talking to an automated system. Some responses are generated by a language model.*" at the start of every session.
2	AI-generated text must be marked in a machine-readable way (Art. 50(2))	⚠ **Gap**	`run_log.json` stores provider and model once in `meta`, but individual answers (probe responses, AURA turns, decoder output) carry no flag. **Fix:** add `"ai_generated": true` and the model name to each LLM-produced record, and mark LLM text in the transcript. FST outputs are rule-based and need no mark.
3	Deep-fake disclosure (Art. 50(4))	✓ N/A	No images, audio or video. The Q5 poem is generated text, not an imitation of a real person.
4	Emotion recognition / biometric categorisation	✓ N/A	Not used. The sarcasm stress test (ST2) shows the FST does **not** read emotion.

#	Requirement	Status	Evidence / fix
	(Art. 50(3))		

5. Security and data checks

Check	Status	Note
API keys kept out of the repository	✓	Keys only in `.env`, which is listed in `.gitignore`. ⚠ `.env.example` **is** committed: it must only ever hold an empty placeholder. Check it before every push.
No personal data in logs (GDPR)	✓	`run_log.json` holds only scripted questions, synthetic ship facts, model outputs and metrics.
Prompt injection against the FST	✓ / ⚠	Instruction-like input ("ignore all previous instructions...") is detected and sent to FALLBACK with nothing stored (stress test ST4). The detection is a fixed pattern list; reworded attacks may pass, so keep it updated.
Prompt injection against the LLMs	✓ Low	The 10 interrogation questions and 5 probe questions are fixed in the code; no user text reaches the LLM in the default run. The decoder reads AURA's own output, so indirect injection is theoretical.
Unsafe action from misunderstood input	⚠ Risk	A sarcastic "Oh YES, brilliant plan..." locked the course (ST2); "Vega, definitely not Mars" stored Mars (ST5); a correction longer than 7 words stored the wrong destination in 85.2% of channel draws (`03` §4.1). **Fix:** require an explicit confirmation phrase that repeats the values, and reject slot changes in messages that hit the 7-word limit.
Hallucination by the LLM decoder	✓ Observed low	In the live run, the decoder wrote UNKNOWN for a lost word and stated no fact that had not reached it (0 of 5). Only tested at low noise; re-test with `--p-noise 0.3`.
Model failure handled safely	✓	Pacing, retry with backoff, Gemini model fallback (used in the live run after 503 errors), offline mock.
Human oversight	✓	Every FST transition is logged in a trace; FALLBACK hands over to a human officer; no course is locked without confirmation.

6. Actions before deployment

1. Add the automated-system / AI disclosure notice (Art. 50(1)).
2. Add `ai_generated` metadata to every LLM-produced record and mark it in the transcript (Art. 50(2)).
3. Strengthen confirmation: explicit phrase with read-back of all slots; reject truncated corrections.
4. Keep the injection pattern list under review; never pass raw user text to an LLM tool.
5. Never let the LLM decide irreversible actions; the deterministic FST stays the authority (`03` §6).
6. Do not use the Anti-Turing rubric to grade people without the full high-risk process.
7. Re-check against the Commission's Article 50 guidelines and Code of Practice on AI-generated content as they are finalised.

This review is a student assessment for a course assignment, not legal advice.